

Platform SRS — STEM Career Path (AI Era)

Project: STEM Graduates Career Path — AI Era (Code For Good) **Doc type:** Software Requirements Specification — **vetted-access learning platform** (Phase 1+) **Owner:** Tinh Cao **Status:** Draft for board approval — v1.0, June 2026 **Relationship to docs/Project SRS.md:** that document specifies **Phase 0 — the static landing page** — and remains its source of truth. *This* document authorizes the platform that the landing page's "Sign Up" and "Donate" calls-to-action eventually lead to. The platform design docs ([Architecture-Design.md](#), [Customer-Journey.md](#), [Sitemap-and-Wireframes.md](#)) take **this document** as their source of truth. **Companion docs:** [docs/Architecture-Design.md](#) · [docs/Customer-Journey.md](#) · [docs/Sitemap-and-Wireframes.md](#) · [docs/Service-Tradeoff-Analysis.md](#) · [docs/Ops-Runbook.md](#)

1. Why this document exists

The original Project SRS authorizes a static landing page. The program's access model — vetted applications, interviews, admin-granted accounts, gated curriculum, donation-supported seats — requires an application platform that the landing-page SRS never described. The [Architecture-Review.md](#) flagged this as a requirements gap (Finding 1): the board should approve the *platform* — its scope, cost, and data custody — against an explicit requirements document, not infer it from design docs.

This SRS is that document. It is deliberately short: it states what the platform must do, what it must not do, what data it holds, what it costs, and what the board is being asked to approve.

2. Product summary

A small, vetted-access learning platform on AWS:

- 1. **Apply.** Visitors submit a short application from the public site.
- 2. **Vet.** An admin reviews, runs a 15-minute interview, and decides: free seat (beneficiary), donate-to-unlock (supporter), or decline.
- 3. **Unlock.** Donations happen entirely on **Zeffy's hosted platform** (the site only links out). An admin confirms the donation in the Zeffy dashboard. Access is **always granted by an admin** — never automatically by a payment event.
- 4. **Learn.** Members sign in (email + password, Cognito) and work through gated curriculum — Path A (full roadmap, 12–18 months) or Path B (fast track, 8–12 weeks) — submitting proof-of-work links. Later stages unlock as prerequisites complete.
- 5. **Lapse or finish.** Access windows expire on schedule or are revoked by an admin; members may re-apply.

3. Scale & team assumptions (sizing basis)

Assumption	Value	Consequence
Maintainer/operator	One person (the owner), volunteer	Architecture must be runnable by a single human; ops is a weekly checklist, not on-call

Assumption	Value	Consequence
Current cohort	None yet — pilot is pre-launch	Build the minimum; defer every cost or component that needs traffic evidence
Pilot cohort size	≤ 100 members; ≤ 300 by end of year 1	Everything fits free tiers; no pre-scaling
Monthly active users	Far below 10,000	Cognito Essentials free tier suffices
Traffic between cohorts	Near zero	Stack must scale to zero (pay-per-use only)
Donations	One-time contributions only, via Zeffy hosted pages	No payment API, webhook, or card data anywhere in our stack

4. Functional requirements

ID	Requirement
F1	Public application form (/apply) collecting: name, email, stage, preferred track, background, links. Includes an age/consent gate (see §6).
F2	Admin queue: list applications by status; schedule interview (Cal.com link); record decision (approve-beneficiary / donation-required / reject) with reason.
F3	Admin grant: provision a Cognito account (no self-sign-up anywhere), set access window and path; idempotent — double-clicks and retries cannot double-provision.
F4	Donation confirmation: admin records a Zeffy payment reference against an application before granting supporter access. No in-app payment processing.
F5	Member app: sign-in, dashboard, curriculum stages, proof-of-work submission (external links), private notes.
F6	Stage gating enforced server-side : locked stages are not retrievable by any client request, not merely hidden in the UI. Admin can override (unlock/re-lock), and overrides are audited.
F7	Access expiry: scheduled job expires lapsed members and sends SES reminders before the window closes; expired members land on /access/expired .
F8	Audit log: every privileged or state-changing action (decisions, grants, revocations, overrides, auth events) appended to an immutable application audit log; admins can view per-member/application history in-app.
F9	Roles: student and admin (Cognito groups). Beneficiary vs supporter is recorded for reporting but grants identical student access.

5. Non-functional requirements

ID	Requirement
N1	Cost : gross AWS run cost ≤ \$200/year at pilot scale; net \$0 against the \$1,000 AWS nonprofit credit target (per Service-Tradeoff-Analysis.md — the single canonical credit figure). No

ID	Requirement
	always-on compute. Fixed-cost security add-ons (WAF, Cognito Plus) require a documented trigger before enabling.
N2	Hosting: AWS only; the public site and SPA shell run on AWS Amplify Hosting (Code For Good's existing platform); no frontend migration to S3+CloudFront unless a phase-2 trigger fires. Gated curriculum is delivered from a separate private-S3 + CloudFront distribution with signed-cookie access (server-side gating, Architecture-Design.md §9.2) — a content-delivery component, not a frontend-hosting migration, with no WAF and free-tier egress.
N3	Security: server-side enforcement of roles, access windows, and gating; least-privilege IAM per function; mandatory MFA for admin accounts ; no card data in our stack (PCI SAQ-A posture via Zeffy).
N4	Accountability: two audit layers (CloudTrail + application AuditLog), append-only by IAM, with a tamper-evident export. Retention ≥ 2 years.
N5	Durability: PITR + deletion protection on every DynamoDB table; documented restore procedure (see Ops - Runbook.md); RPO ≤ 24 h, RTO ≤ 1 business day (volunteer-run program; board accepts this explicitly).
N6	Privacy: data minimization, per-table retention (see §6), audit events free of PII payloads, and a deletion path for non-member PII.
N7	Maintainability: one repo, ≤ 3 deployed functions at launch, IaC (SAM/CDK), no click-ops in prod; a student volunteer should be able to operate it from Ops - Runbook.md .

6. Data handling summary (board-facing)

The platform holds applicant and member personal data, **including data from high-school students who may be minors**. Zeffy holds all donor payment data; Calendly/Cal.com holds scheduling data.

Data	Where	Retention	Deletion path
Applications (name, email, background, links)	DynamoDB Applications	Active + 12 months after final state for rejected/expired applications (TTL auto-purge)	TTL, or admin delete on request
Member profile & progress	DynamoDB Members/Progress/Notes	Membership + 24 months	Admin off-boarding procedure
Audit events	DynamoDB AuditLog (+ WORM export)	≥ 2 years, immutable	None — by design, events contain IDs and status codes only, never PII payloads , so immutability does not trap personal data

Data	Where	Retention	Deletion path
Donor/payment data	Zeffy only	Zeffy's policy	Zeffy's process
Card data	Nowhere in our stack	—	—

Minors: the [/apply](#) form asks date-of-birth bracket; applicants under 13 are not accepted (COPPA); applicants 13–17 require a guardian consent acknowledgment before an interview is scheduled. The board is asked to approve this policy (or set a stricter one) before launch.

7. Explicitly out of scope (launch)

In-app payment processing, Stripe/PayPal webhooks, recurring billing, refunds automation (handled in Zeffy by the admin), AWS WAF, Cognito Plus threat protection, multi-account AWS Organizations governance, mobile apps, self-service sign-up, and any AI/recommendation features. Each deferred item has a written re-entry trigger in [Architecture-Design.md](#) §14.

8. Phasing

Phase	Deliverable	Status
0	Static landing page (per Project SRS.md)	In progress — ships first, independently
1	This platform: apply → vet → grant → learn → expire, Zeffy link-out, audit, runbook	This SRS
2	Evidence-triggered hardening: WAF, Cognito Plus, CloudTrail data-event expansion, 6-function split, Organizations/SCP governance	Triggers in Architecture-Design.md §14
3	Automated payments (Stripe hosted Checkout + signed webhooks)	Appendix A of Architecture-Design.md ; requires board decision on fees

9. What the board is asked to approve

1. The platform scope above (Phase 1), as the successor to the landing-page SRS.
2. The data-handling and minors policy in §6.
3. The cost envelope in N1 and the **\$1,000 nonprofit credit** application (Need to submit by July 2026 for next Fiscal year with \$95 fee).
4. The volunteer-run operating posture in N5/N7 (best-effort response, weekly ops checklist, named board contact for severe alerts — see [Ops-Runbook.md](#)).
5. Day-1 governance: single AWS account; root credentials sealed with MFA and lodged with a named board custodian; graduation to AWS Organizations/SCPs when a second custodian exists ([Architecture-Design.md](#) §6.3).

10. Acceptance criteria

Phase 1 is done when the [Architecture-Design.md](#) §16 build checklist passes, the [Ops-Runbook.md](#) restore procedure has been tested once, and a dry-run cohort of test accounts has exercised: apply → approve → grant → sign-in → locked stage rejected server-side → submit deliverable → stage unlock → expiry → [/access/expired](#).